Безопасность и персональные данные

Что и как защищено в «Взаимно»: соответствие 152-ФЗ на техническом уровне, роли и разграничение доступа, защита паролей и токенов, ограничение частоты запросов, приватность данных кандидата до раскрытия, шлюз LLM. Все утверждения сверены с кодом (`backend/app/core` , `app/api` , `app/contact` , `app/llm`) и тестами. Разделы «Известные ограничения» и «В разработке» — честный перечень того, что ещё не закрыто.

Документ описывает **техническую реализацию** требований. Организационные меры оператора (уведомление Роскомнадзора, политика обработки ПДн, приказы, договоры с хостингом и почтовым провайдером) находятся вне кода и должны быть выполнены организацией, развёртывающей платформу.

Содержание: 1. 152-ФЗ · 2. Роли и доступ · 3. Пароли и токены · 4. Ограничение частоты · 5. ПДн до раскрытия · 6. LLM-шлюз · 7. Секреты и инфраструктура · 8. Целостность теста · 9. Угрозы · 10. Ограничения

1. Персональные данные и 152-ФЗ

1.1. Какие данные обрабатываются

Группа	Состав	Где хранится	Кто видит
Учётные	email, хеш пароля (argon2id), роль, статус	`users`	Владелец; администратор БД
Профиль кандидата	ФИО, контакты, текущий работодатель, вуз, город, минимум зарплаты, настройки приватности	`candidate_profiles`	Владелец; работодатель — **только после взаимного «да»**, только разрешённые кандидатом поля
Опрос, тест	Ответы опроса, ответы теста, время ответов, события страницы (уход со вкладки, вставка)	`survey_responses` , `test_responses` , `session_events` , `flags`	Владелец; методист; работодатель — только итоговая категория и полоса
Резюме	Распознанные поля и текст резюме (файл PDF **не сохраняется**: разбирается в памяти, хранятся текст и sha256)	`candidate_profiles`	Владелец; работодатель — после «да» и только при разрешённом поле «Резюме»
ФСП	Привязка `fsp_id` (= `sub`), ответ реестра, нормализованные результаты	`fsp_links` , `fsp_achievements`	Владелец; работодатель — обобщённо до раскрытия, выписка после
Журналы	Согласия (с IP и user-agent), аудит действий	`consents` , `audit_log`	Владелец (журнал согласий); администратор
Не собираются	Биометрия (камера, микрофон), геолокация, возраст и пол в явном виде, паспортные данные	—	—

1.2. Требования и их реализация

Требование	Реализация
Согласие, раздельное и конкретное (ст. 9)	Шесть **отдельных** целей (`ConsentPurpose`): `processing` (обработка ПДн, при регистрации, обязательное), `blind_card` (показ слепой карточки работодателям), `fsp_enrichment` (данные ФСП), `contact_disclosure` (передача контактов **конкретной компании**), `test_logging` (журналирование событий теста), `calibration` (обезличенные ответы для калибровки заданий). Каждое согласие — своя запись `consents` с `purpose` , `text_version` , `granted_at` , `revoked_at` , `scope` , `ip` , `user_agent` . Тексты — `GET /api/consents/documents`
Версионирование текстов	Человек соглашается с тем текстом, который видел; устаревшая версия → `409 consent_outdated` . Старые согласия хранят свою версию

Требование	Реализация
Отзыв без потери доказательств	Запись не удаляется, ставится `revoked_at`; повторное согласие — новая запись. Отзыв цели без контекста гасит все действующие записи цели. Отзыв `contact_disclosure` гасит раскрытие у компании: контакты снова скрыты, приглашение переходит в `consent_revoked`, пара получает паузу 14 дней. Отзыв `fsp_enrichment` удаляет сохранённые данные реестра
Согласие на передачу контактов — контекстное	Выдаётся только в приглашении или отклике (`POST /accept`, `POST /api/applications`, `POST /grant-consent`), не через общий журнал (`400 consent_contextual`)
Журнал	`GET /api/consents`, `GET /api/candidates/me/consents` — все согласия, включая отозванные. Аудит значимых действий (вход, выдача токенов, согласия, раскрытия, вход через ФСП ID) — `audit_log`; в `payload` нет ПДн, только идентификаторы и коды причин
Минимизация и цель (ст. 5)	Работодатель получает слепую проекцию (раздел 5); поля раскрытия выбирает кандидат; ПДн реестра ФСП работодателю не передаются; из ФСП ID сохраняются только служебные claims
Локализация хранения (ст. 18, ч. 5)	Архитектура не содержит зарубежных зависимостей на пути ПДн: база данных, бэкенд, Keycloak и фронтенд разворачиваются на **серверах в РФ** (требование к развёртыванию, см. DEPLOY.md); шрифты и 3D-иллюстрации самохостятся, внешних CDN, счётчиков и аналитики во фронтенде нет; LLM по умолчанию выключена, поддерживаются российские провайдеры (YandexGPT, GigaChat) с маскированием ПДн; для SMTP следует выбирать провайдера с инфраструктурой в РФ. Исключение: страницы `/api/docs` и `/api/redoc` подгружают скрипты с `cdn.jsdelivr.net` (ПДн туда не передаются; на проде рекомендуется отключить документацию или раздавать статику локально)
Автоматизированные решения (ст. 16)	Платформа не принимает юридически значимых решений о человеке без участия человека: Score — ранжирование для работодателя, решение о приглашении и найме принимает человек; грейд — «решение с уровнем доверия», при подозрении сессия уходит методисту; автоматического бана нет; LLM не участвует в тесте, ключах, Score, ранжировании и вердиктах. Кандидат видит свои флаги и может оспорить (`POST /api/tests/flags/{id}/dispute`)
Права субъекта (ст. 14)	Доступ и исправление: профиль, настройки, журнал согласий; отзыв согласий — в журнале; отвязка ФСП ID с удалением данных — `DELETE /api/fsp/me`; удаление резюме — `DELETE /api/candidates/me/resume`. **Удаление аккаунта целиком** — `DELETE /api/candidates/me` (кандидат) и `DELETE /api/companies/me` (работодатель) с подтверждением паролем (для аккаунта без пароля — слово «УДАЛИТЬ»), п. 1.3
Меры защиты (ст. 19)	Argon2id, TLS на периметре, роли и контроль владельца записи, шифрование ключей заданий, HMAC-псевдонимы, rate limit, аудит, непривилегированный контейнер (разделы 2–8)
Несовершеннолетние	Младше 15 лет регистрация отклоняется; 15–17 лет — профиль не виден работодателям, пока законный представитель не подтвердит согласие по ссылке из письма; после этого — только стажировка или лёгкий труд на неполный день; год рождения из реестра ФСП важнее заявленного; п. 1.4
Биометрия	Камеры, микрофона и сканера процессов в тесте нет сознательно: это биометрия и инвазивный контроль
Сроки хранения	Ночная задача планировщика (`config/privacy.yaml`, `config/scheduler.yaml`): неподтверждённые аккаунты удаляются через 7 дней, просроченные коды и токены чистятся, IP в журнале аудита (180 дней) и в записях согласий (365 дней) обезличиваются; п. 1.3

1.3. Удаление аккаунта и сроки хранения

Удаление по запросу (`app/services/account/erasure.py`, `config/privacy.yaml`). `DELETE /api/candidates/me` и `DELETE /api/companies/me` принимают `{"password": "…"}`; аккаунт без пароля (вход через ФСП ID без заданного пароля) подтверждается словом «УДАЛИТЬ» в `confirm`. Неверный пароль — `403 password_invalid`, аккаунт не тронут; попытки считаются лимитом (5 в час на аккаунт), поэтому удаление нельзя использовать для подбора пароля. Что происходит:

1. Строка `users` удаляется одним запросом. Все внешние ключи на `users` и `companies` объявлены `ON DELETE CASCADE` или `SET NULL` (проверяет тест `test_every_foreign_key_to_users_and_companies_cascades_or_nulls`), поэтому база сама убирает профиль и резюме, ответы опроса, признаки подбора, сессии теста и ответы, согласия, привязку ФСП ID и данные реестра, приглашения, отклики, раскрытия контактов, уведомления, коды и refresh-токены — все сессии на всех устройствах перестают работать, cookie очищается.

2. Что не связано внешним ключом, чистится явно: тексты обратной связи по приглашениям и откликам кандидата, контакты кандидата в копиях вебхуков ATS (журнал доставок компании), IP и ссылки на человека в записях журнала аудита.
3. Остаётся только то, что не относится к человеку: запись журнала аудита «аккаунт удалён» (роль, дата, способ — без ПДн), счётчики надёжности компаний (`reliability_events` без ссылки на кандидата и приглашение), откалиброванные параметры заданий.
4. Работодатель: удаляется его аккаунт. Если он был последним в компании — ждущие приглашения отзываются («позиция закрыта», кандидат получает уведомление), брифы и вакансии закрываются, контакты связи и вебхук ATS стираются; название компании (не ПДн) остаётся в истории приглашений кандидатов.
5. На почту уходит письмо-подтверждение; адрес нигде не сохраняется. Тот же email можно зарегистрировать заново.

Сроки хранения (`config/privacy.yaml → retention` ; ночная задача `retention` встроенного планировщика, см. «Планировщик» в ARCHITECTURE.md): неподтверждённые аккаунты старше 7 дней удаляются целиком; сожжённые коды подтверждения (2 дня), просроченные и отозванные refresh-токены (30 дней), брошенные входы через ФСП ID (1 день) — чистятся; IP в журнале аудита (180 дней) и IP/user-agent в записях согласий (365 дней) обезличиваются (поле → `NULL` , сама запись и версия текста остаются). Сроки хранения основных данных активных аккаунтов определяет оператор в политике обработки (организационная мера).

Минимизация данных реестра ФСП. Из ответа реестра сохраняется только то, что платформа использует: `sub` и год рождения спортсмена (политика по несовершеннолетним), результаты и разряды без номера приказа и без `sub` других участников команд. ФИО, дата рождения целиком, регион и организация не сохраняются (`app/services/fsp_link/minimize.py` , `config/privacy.yaml → fsp_registry`).

1.4. Несовершеннолетние 15–17 лет: согласие законного представителя

Ответы организаторов: с 15 лет допустим только лёгкий труд, согласие законного представителя на обработку ПДн нужно с 15 до 17 лет включительно. Все пороги — `config/contact.yaml → minors` , в коде чисел нет.

Что делает платформа:

1. **Возраст.** Хранится только год рождения (`candidate_profiles.birth_year`); возраст считается осторожно, «минимально возможный» = текущий год − год рождения − 1 (при сомнении считаем моложе). Год спрашивается при регистрации кандидата (`birth_year` в `POST /api/auth/register`) и в профиле (`PUT /api/candidates/me`). Если год рождения подтверждён реестром ФСП, заявленный не заменяет его.
2. **Младше `registration_min_age` (15 лет).** Регистрация отклоняется кодом `422 age_too_young` с объяснением; аккаунт и профиль не создаются, ничего не сохраняется. То же при попытке указать такой год в профиле.
3. **15–17 лет (`guardian_consent_below_age` = 18).** Кандидат указывает ФИО и email представителя (`POST /api/candidates/me/guardian`). На этот адрес уходит письмо (в разработке видно в Mailpit) со ссылкой на `/guardian-confirm?token=…` . Токен одноразовый, действует 7 дней (`token_ttl_hours`), в базе лежит только его SHA-256; повтор письма на тот же адрес — не чаще раза в 10 минут. Представитель подтверждает согласие без входа (`POST /api/guardian/confirm` , ограничение частоты `rl_guardian_ip`). Email представителя не может совпадать с адресом кандидата. В письме email кандидата показан с маской.
4. **До подтверждения** профиль не попадает в подборки и банк (`age_ok` в признаках подбора), прямое приглашение невозможно (`candidate_unavailable` , причина работодателю не раскрывается), в «Приватности» кандидат видит причину «нужно согласие законного представителя».
5. **После подтверждения** кандидат виден только брифам с флагом «стажировка / лёгкий труд». В его слепой карточке есть плашка «Кандидату 15–17 лет: только стажировка или лёгкий труд, неполный день» (возраст и год рождения не раскрываются никогда); приглашение не на стажировку отклоняется с `minor_internship_only` и понятным текстом.
6. **Смена представителя** сбрасывает прежнее согласие. Достижение 18 лет (расчёт по году) снимает ограничения; при смене года рождения на совершеннолетний данные представителя стираются.

7. **Аудит.** Запрос письма (`guardian.requested`) и подтверждение (`guardian.confirmed`) пишутся в журнал аудита без ПДн.

Что остаётся организационным (не в коде): проверка того, что указанный адрес действительно принадлежит родителю или опекуну, платформа технически не проверяет (email не доказывает родство) — это допущение MVP; промышленный режим потребует подписанного согласия (УКЭП или Госуслуги) и отзыва согласия представителем без обращения в поддержку. Отзыв сейчас — через удаление аккаунта (п. 1.3) или обращение к оператору.

2. Роли и разграничение доступа

Четыре роли (`candidate` , `employer` , `methodist` , `admin`). Роль и статус аккаунта проверяются **по БД на каждом запросе**: блокировка и смена роли действуют сразу, не дожидаясь истечения токена. Доступ к маршрутам задаётся зависимостью `require_roles(…)` ; нарушение — `403 role_forbidden` .

Область	Кандидат	Работодатель	Методист / админ
Профиль, опрос, тест, ФСП, согласия, задачи (`/api/survey` , `/tests` , `/candidates/me` , `/fsp/me` , `/tasks/me`)	свои данные	—	—
Бриф, подборка, банк, шортлист, приглашения, вакансии, задачи компании, профиль компании	—	данные **своей компании**	—
Ответы на приглашения, отклики, просмотр вакансий	да	—	—
Надёжность любой компании, уведомления, журнал согласий	да	да	да
Лаборатория (`/api/lab/*`): банк и клоны, трасса, флаги, калибровка, валидация	—	—	да
Администрирование (`/api/admin/*` : импорт жюри, ранжирование, метрики, валидация)	—	—	только `admin`
Демо-режим (`/api/demo/*` , только при `VZ_DEMO_MODE=true` , иначе 404)	вне `VZ_ENV=prod` — любая роль для часов, сброса, автоответчика и режима жюри; в prod эти общие кнопки — только `admin` (или заголовок `X-Demo-Key`), п. 10	то же	то же

Защита от IDOR (`app/core/access.py`): запись, принадлежащая другому пользователю, **неотличима от несуществующей — 404, а не 403**, иначе по кодам ответа можно было бы перебирать чужие идентификаторы. `ensure_owner` / `get_owned_or_404` сравнивают владельца записи с `user_id` или `company_id` пользователя; некорректный UUID тоже даёт 404. Для работодателя кандидаты адресуются только непрозрачной ссылкой `ref` , которая вычисляется HMAC и разрешается **только в рамках его компании** (`candidate_aliases`): угадать `ref` другой компании нельзя. Дополнительные проверки: пригласить можно только того, чью карточку открывали или кто в шортлисте; полный PDF-профиль работодателю — только при действующем раскрытии (иначе 404); кандидату доступны только его собственные сессии теста, флаги и разбор.

Проверяется тестами `tests/test_platform_access.py` , `tests/test_platform_security.py` , `tests/test_platform_password.py` , `tests/test_platform_auth.py` , `tests/test_api_contact_privacy.py` , `tests/test_api_needs_privacy.py` , `tests/test_api_profile_privacy.py` .

3. Пароли и токены

3.1. Пароли

Мера	Параметры
Хеширование	**argon2id** (`argon2-cffi`): время 3, память 64 МиБ, параллелизм 4 (`VZ_ARGON2_*`); автоматический перехеш при изменении параметров
Политика	8–128 символов, хотя бы одна буква и одна цифра
Защита от перебора и перерасхода памяти	Не больше 4 хешированый одновременно (`VZ_ARGON2_MAX_CONCURRENT`): иначе пачка входов выела бы память контейнера (по 64 МБ на хеш)
Защита от выяснения аккаунтов	Для неизвестного email пароль всё равно хешируется (одинаковое время ответа); ответ входа одинаков для неизвестного email и неверного пароля; статус аккаунта проверяется **после** пароля; ответ восстановления пароля не выдаёт, есть ли аккаунт
Восстановление	Код на email (6 цифр, 15 минут, 5 попыток), после смены пароля **все сессии пользователя завершаются**

3.2. Токены и коды

Элемент	Реализация
Access-токен	JWT (PyJWT), HS256, срок 15 минут; обязательные claims `exp` , `iat` , `sub` , `type` , `iss` ; алгоритм задан списком (защита от `alg=none` и подмены алгоритма); тип `access` проверяется. Хранится в памяти клиента, не в cookie и не в `localStorage`
Refresh-токен	Непрозрачные 256 бит (`secrets.token_urlsafe(32)`), в БД только **sha256**. Cookie `vz_refresh` : `HttpOnly` , `Path=/api/auth` , `SameSite=Lax` (`Secure` обязателен в проде)
Ротация и обнаружение кражи	Каждый `refresh` выдаёт новый токен той же цепочки (`family_id`), старый помечается использованным. Повторное предъявление использованного токена — цепочка отзывается (`401 refresh_reused`); повтор в пределах 10 с трактуется как гонка вкладок (`409 refresh_superseded`). `logout` отзывает всю цепочку устройства. Access-токен после выхода живёт до истечения (до 15 минут), но сервер сверяет статус аккаунта по БД
Коды email	6 цифр от `secrets.randbelow` ; в БД — **HMAC-SHA256** от пары « `user_id` , код» ключом `VZ_APP_SECRET` (утечка таблицы не раскрывает коды: перебор 10^6 без секрета не сходится); сравнение `hmac.compare_digest` ; новый код гасит предыдущие; 5 попыток на код; повторная отправка не чаще раза в 60 с и 5 писем в час
CSRF	Состояние меняется только запросами с заголовком `Authorization: Bearer` , которого межсайтовая форма отправить не может; единственная cookie (`vz_refresh`) ограничена путём `/api/auth` и `SameSite=Lax` . Страница сверки `/api/v/{code}` и `GET` -маршруты состояния не меняют
Заголовки	`X-Content-Type-Options: nosniff` , `X-Frame-Options: DENY` , `Referrer-Policy: strict-origin-when-cross-origin` , `Cache-Control: no-store` на `/api/auth/*` . HSTS и TLS задаёт Caddy (см. DEPLOY.md); CSP интерфейса — `frontend/csp.conf` , подключается nginx образа `web` (ENGINEERING.md): `default-src 'self'` , скрипты только `'self'` , `'unsafe-inline'` лишь для стилей (React и Tailwind задают встроенные), `object-src 'none'` , `frame-ancestors 'none'` ; на `/api/` политика не накладывается (Swagger UI бэкенда использует встроенные скрипты)
Вход через ФСП ID	OIDC authorization code + PKCE S256; `state` (в БД только sha256, одноразовый), `nonce` , привязка к браузеру cookie `vz_fsp_flow` ; проверка подписи id_token по JWKS, `iss` , `aud` , `nonce` , срока; HS-алгоритмы и `none` запрещены; email из ФСП ID не даёт права на чужой аккаунт; защита от «предзахвата» аккаунта (см. FSP_INTEGRATION.md)

4. Ограничение частоты запросов

Токен-корзина (`app/core/rate_limit.py`): ключ — email, IP или аккаунт; превышение — `429` с `Retry-After` . Лимит проверяется **до** проверки пароля: перебор упирается в 429 независимо от результата.

Область	Лимит
Вход	5 за 300 с на email, 30 за 300 с на IP

Область	Лимит
Регистрация	10 в час на IP
Ввод кода, новый пароль	10 за 900 с на email
Повторная отправка кода, запрос восстановления	20 в час на IP
Обновление сессии	60 в минуту на IP
Вход через ФСП ID, демо-вход	30/300 с, 30/300 с, 20/300 с на IP
Тест: создание сессии, `next`, ответ, события	10 в час, 120, 60, 120 в минуту на аккаунт
Резюме, PDF, сверка по QR	10 в час; 30 за 600 с; 120 в минуту (QR — на IP)
Подбор, приглашения, отклики, задачи, вебхук	30, 30, 10, 20, 5 в минуту

Полная таблица — в API.md. Квоты бизнес-уровня (антифейк): не больше 20 активных приглашений на бриф, 60 новых на домен за 7 дней (для личных почтовых доменов — на аккаунт), пачка до 10, лимит кандидата 3/5/10/∞ в неделю, пауза пары, стоп-слова («предоплата», паспорт/СНИЛС до собеседования, контакты в тексте, короткие ссылки) с плашкой «Требует осторожности».

Ограничение: корзины лежат в памяти процесса. Один процесс uvicorn — лимит точный; при нескольких воркерах он действует на воркер.

Клиентский IP за обратным прокси. Приложение само решает, чему верить (`app/core/netutil.py`, `app/core/rate_limit.client_ip`): заголовок `X-Forwarded-For` принимается **только если TCP-сосед — доверенный прокси** из `VZ_FORWARDED_ALLOW_IPS` (то же имя, что у uvicorn: читается и `FORWARDED_ALLOW_IPS`; список адресов и подсетей через запятую, по умолчанию `127.0.0.1`). Цепочка читается справа налево: первый недоверенный адрес — настоящий клиент, всё левее подделывается клиентом и игнорируется; мусор в заголовке — откат к адресу соседа. `*` разрешён только вне prod. Uvicorn запускается с `--no-proxy-headers`, чтобы правило было одно. В схеме с Caddy (docker-compose.prod.yml): подсеть compose зафиксирована (`172.29.80.0/24`) и указана в `VZ_FORWARDED_ALLOW_IPS`, Caddy перезаписывает `X-Forwarded-For` адресом клиента (`header_up X-Forwarded-For {remote_host}`), бэкенд наружу не публикуется. Без этой настройки все пользователи за прокси выглядели бы как один IP и делили лимиты, а с `*` любой, кто дотянулся бы до порта, выбирал бы себе IP сам. Проверяется `tests/test_hardening_api.py`.

5. ПДн кандидата до раскрытия

Работодатель до взаимного «да» (или отклика) получает **слепую проекцию** `CandidateBlind`; контакты и разрешённые поля — `CandidateDisclosed` только при действующей записи `ContactDisclosure` этой пары. Решает не вызывающий код, а согласие: `services.contact.profiles` выбирает проекцию по действующему раскрытию.

Мера	Реализация
Белый список полей	Матрица `config/contact.yaml → visibility`: поле, которого в ней нет, не попадает ни в одну проекцию. Возраст, пол, дата рождения, внутренний id — «никогда» в обеих проекциях; конфиг, нарушающий это, не загружается
Вычищение ПДн в глубину	В слепой проекции ПДн-ключи (`full_name`, `email`, `phone`, `telegram`, `resume`, `city`, `fsp_id`, `ekp`, `team`, `protocol_url`, … — список `pii_fields`) удаляются на любой вложенности
Псевдоним и ссылка	«К-4821» = `HMAC(VZ_PSEUDONYM_SECRET, компания ‖ кандидат)`; `ref` — отдельный HMAC; свои у каждой компании: две компании не сопоставят карточки одного человека
Доказательства	Внутренние id попыток теста, задач, записей ФСП наружу не уходят: непрозрачные HMAC-ссылки в рамках компании; номера ЕКП, команды и ссылки на протоколы — только после раскрытия
Обобщение	Тест — полоса «топ-10/25/50 %» и интервал с шагом 10 баллов; ФСП — дисциплина, уровень, год, полоса места; зарплата — «в вилке ✓ / выше» (превышение округляется до полосы 5 %, чтобы точный минимум не восстанавливался из Score); охват вилки — при N ≥ 10 и ступенями не меньше 3 человек

Мера	Реализация
Свободный текст	Комментарии кандидата, уходящие до раскрытия, проверяются на контакты и ссылки
PDF-профиль	Полная версия работодателю — только при действующем раскрытии и с теми полями, что разрешил кандидат (иначе 404); слепая версия — псевдоним вместо имени. Страница сверки `/api/v/{code}` — публичная, без ПДн, `X-Robots-Tag: noindex`, `Cache-Control: no-store`; код — HMAC содержимого листа, изменённый PDF не пройдёт сверку
Вебхуки ATS	Подпись HMAC-SHA256 (`X-Vzaimno-Signature`), идемпотентный `X-Vzaimno-Event-Id`; контакты кандидата в событии — только при действующем согласии; защита от SSRF: URL проверяется при сохранении и перед каждой доставкой, внутренние, частные, link-local адреса, метаданные облака и служебные зоны запрещены
Контрактные тесты	«0 ПДн-ключей в ответах работодателю до согласия» — `tests/test_contact_privacy.py`, `tests/test_api_contact_privacy.py`, `tests/test_api_needs_privacy.py`, `tests/test_api_profile_privacy.py`

6. LLM-шлюз с маскированием

LLM **выключена по умолчанию** (`VZ_LLM_PROVIDER=none`). Допустима только через шлюз `app/llm/gateway.py`, и только в разборе брифа и резюме; в тесте, ключах, Score, ранжировании, объяснениях и вердиктах она архитектурно запрещена (тест `test_ranking_path_never_imports_llm`).

Мера	Реализация
Маскирование ПДн **до** вызова	`app/llm/masking.py`: email, телефоны, ссылки на профили и Telegram, строки с датой рождения и возрастом, ФИО (найденные правилами) заменяются на `*`; **длина текста сохраняется**, поэтому смещения цитат совпадают с исходным текстом
Только добавление, только с цитатой	Каждое поле от модели обязано прийти с цитатой, найденной в тексте (`rapidfuzz.partial_ratio ≥ 90`); поле без цитаты отбрасывается. LLM не может изменить результат правил, только дополнить
Детерминированный fallback	Цепочка YandexGPT → GigaChat → «без LLM»; сбой, таймаут (общий бюджет 20 с) или пустой ответ — результат правил не меняется
Кэш и воспроизводимость	Кэш по `sha256` замаскированного текста; режимы `record` и `replay` (кассета JSON без сети и ключей): в кассете нет текста запроса и ПДн, только ключ sha256 и ответ модели на замаскированный текст
Секреты	Ключи провайдеров — `SecretStr` из окружения; в логи не пишутся
Юрисдикция	Поддерживаются российские провайдеры; GigaChat — с проверкой TLS (путь к сертификату НУЦ Минцифры в `VZ_LLM_GIGACHAT_VERIFY`)

7. Секреты и инфраструктура

Тема	Реализация и требования
Секреты	`VZ_JWT_SECRET` (подпись access-JWT), `VZ_APP_SECRET` (HMAC кодов email, ключ шифрования клонов, секретные seed клонов, подпись демо-токена ФСП), `VZ_PSEUDONYM_SECRET` (псевдонимы и `ref`). В `VZ_ENV=prod` бэкенд **не стартует** с dev-значениями, секретами короче 32 символов и без `VZ_COOKIE_SECURE=true`. Генерация: `python -c "import secrets; print(secrets.token_urlsafe(48))"`
Последствия смены секретов	`VZ_JWT_SECRET` — все пользователи выходят; `VZ_APP_SECRET` — **пул клонов перестаёт расшифровываться** (его нужно пересоздать), действующие коды email теряют силу; `VZ_PSEUDONYM_SECRET` — новые псевдонимы и ссылки (выданные ранее сохранены в `candidate_aliases`). Секреты хранить в менеджере секретов или защищённом `.env` (файл `.env` в git не попадает)
Ключи заданий	`item_instances.key_enc` — Fernet (AES-128-CBC + HMAC), ключ шифрования выводится из `VZ_APP_SECRET` отдельной меткой; дамп БД без секрета ключи не раскрывает. Seed боевых клонов — `HMAC(VZ_APP_SECRET, семейство, номер)` в `[2^50, 2^62)`
Контейнер	`python:3.12-slim`, процесс от непривилегированного пользователя (uid 10001, без shell), зависимости строго по `uv.lock`, healthcheck, лимиты памяти. Прод-схема (`docker-compose.prod.yml`): БД и бэкенд наружу не публикуются, образы закреплены по версиям, Keycloak — в режиме `start` (не `start-dev`) со своей БД

Тема	Реализация и требования
Сеть	В проде наружу публикуется только HTTPS (Caddy, порты 80 и 443). Порты PostgreSQL (5432), Mailpit (8025, 1025), `fsp-mock` (8001), Keycloak (8080) **не публиковать**: в `docker-compose.yml` они открыты для удобства разработки
Keycloak	Профиль `fsp` запускает `start-dev` — только для демо. В проде ФСП ID — внешний сервис ФСП; собственный Keycloak, если нужен, запускается в режиме `start` с TLS, настоящим hostname и закрытой админкой
Реестр ФСП	В демо — статический bearer-токен (`FSP_MOCK_TOKENS`, сравнение за постоянное время); в проде — client credentials сервисного аккаунта
Загрузка резюме	Только PDF, до 5 МБ и 10 страниц, разбор в памяти, файл не сохраняется
Логи	`audit_log` без ПДн; почтовый бэкенд `console` пишет письма (с кодами) в лог — только для разработки
Зависимости	Версии зафиксированы `uv.lock` и `package-lock.json`; список — THIRD_PARTY.md. Автоматический аудит уязвимостей зависимостей в CI — в разработке

8. Целостность теста и ключи заданий

Защита результатов теста от подделки описана в TESTING_MECHANISM.md. С точки зрения безопасности данных важно:

- условие задания отдаётся без ключа и тегов дистракторов; разбор с ключом — только по своему экземпляру и после решения;
- журнал событий страницы теста пишется **только с согласием** `test_logging`; камеры и микрофона нет;
- флаги целостности работодателю не показываются; кандидат видит свои без источника и может оспорить; решение по сессии на проверке принимает методист, автоматического бана нет;
- «Антиподсказчик» формулирует улики фактами, без обвинений.

9. Модель угроз (кратко)

Угроза	Меры
Подбор паролей, перебор кодов	Лимиты до проверки пароля, argon2id, 5 попыток на код, блокировка аккаунта админом
Перебор чужих идентификаторов (IDOR)	404 вместо 403, `ref` по HMAC в рамках компании, проверка владельца на каждой записи
Кража refresh-токена	httpOnly, хеш в БД, ротация, обнаружение повторного использования, завершение цепочки
Утечка БД	Хеши паролей argon2id, HMAC кодов, sha256 refresh, зашифрованные ключи клонов; ПДн открытым текстом — в профиле (поля раскрытия), поэтому доступ к БД и бэкапам ограничивается организационно
Деанонимизация кандидата	Слепая проекция, обобщение, HMAC-псевдонимы, округление зарплатных сигналов, ограничение охвата, вычищение ПДн-ключей
Накрутка и спам работодателей	Квоты, лимит кандидата, пауза пары, стоп-слова, надёжность R с видимой разбивкой, жалобы
SSRF через вебхук ATS	Проверка URL и разрешённых адресов при сохранении и доставке
Слив заданий	Одноразовые клоны, секретные seed, шифрование ключей, детектор «чужого ключа», CUSUM
Утечка ПДн в LLM	Маскирование до вызова, выключено по умолчанию, кассета без текста запроса
Захват аккаунта через ФСП ID	PKCE, `state` привязан к браузеру и аккаунту, подтверждение email, запрет входа в чужой аккаунт по совпавшему email
SQL-инъекции	Запросы строит SQLAlchemy с параметрами; ручные `text()`-запросы используют связанные параметры

Угроза	Меры
HTML-инъекции в письмах и PDF	Динамические значения в HTML-письмах экранируются (`html.escape`); PDF рисуется векторно через reportlab, пользовательский HTML не вставляется

10. Известные ограничения и «в разработке»

Тема	Состояние
Согласие законного представителя 15–17 лет	Реализовано (п. 1.4); ограничение MVP — адрес представителя не сверяется с документом, отзыв согласия представителем — через поддержку или удаление аккаунта
Rate limit при нескольких воркерах	Корзины в памяти процесса; общая корзина (Redis или PostgreSQL) — в разработке
CSP интерфейса	Реализовано: `frontend/csp.conf` (см. строку «Заголовки» и ENGINEERING.md); остаток — `'unsafe-inline'` для стилей и отсутствие CSP на `/api/docs` ; HSTS и TLS — на Caddy
Subresource Integrity	Не нужна: внешних скриптов и стилей нет, всё отдаётся с того же origin
Аудит зависимостей	Реализован в CI: `pip-audit` и `npm audit --omit=dev` (ENGINEERING.md)
`/api/docs` , `/api/redoc`	Ассеты Swagger UI и ReDoc лежат в `backend/app/static/docs` и отдаются самим бэкенд-ом (`/api/docs-assets` , лицензии рядом): ни CDN, ни Google Fonts
Регистрация показывает занятость email	`409 email_taken` для подтверждённого адреса (вход и восстановление пароля занятость не выдают)
Access-токен не отзывается до истечения	До 15 минут; статус и роль проверяются по БД, блокировка действует сразу
Секреты вебхуков ATS	Ключ HMAC компании хранится в БД открыто (нужен для подписи); ротация — `POST /api/companies/me/webhooks/rotate-secret`
Вебхуки: смена DNS между проверкой и соединением (TOCTOU)	Остаточный риск, принят для MVP
Хранение ответа реестра ФСП	Только при согласии и только нужные поля: `sub` и год рождения спортсмена, результаты без `sub` других участников команд, разряды без номера приказа (`app/services/fsp_link/minimize.py` ; старые строки дочищает ночная задача)
Резервное копирование и мониторинг	Не входят в репозиторий; настраиваются при развёртывании
Кандидат без доступа к почте	Единственный канал подтверждения — email; код приходит только на него
Демо-режим на боевом стенде	`VZ_DEMO_MODE=true` открывает `/api/demo/*` : «режим жюри» показывает верные ответы на задания, `GET /api/demo/accounts` перечисляет демо-логины (без паролей), пароли демо-аккаунтов выводятся из `VZ_APP_SECRET` . Общие кнопки (часы, сброс, автоответчик, переключатель режима жюри) в `VZ_ENV=prod` доступны только роли `admin` или заголовку `X-Demo-Key` (`VZ_DEMO_CONTROL_KEY`); явная настройка — `VZ_DEMO_CONTROLS_ADMIN_ONLY` . Включать `VZ_DEMO_MODE` **только** на стенде для жюри; в боевом режиме держать `false` (тогда `/api/demo/*` — 404).